

Progress report 1 of 10

RAG-Augmented Multi-Agent LLM Framework for Explainable Software Vulnerability Detection Using CWE Knowledge Bases

Richa Verma (25MCSS02) Advisor: Dr. Akshay Pandey

The question

This is the first report. It only says what we want to build.

What we did

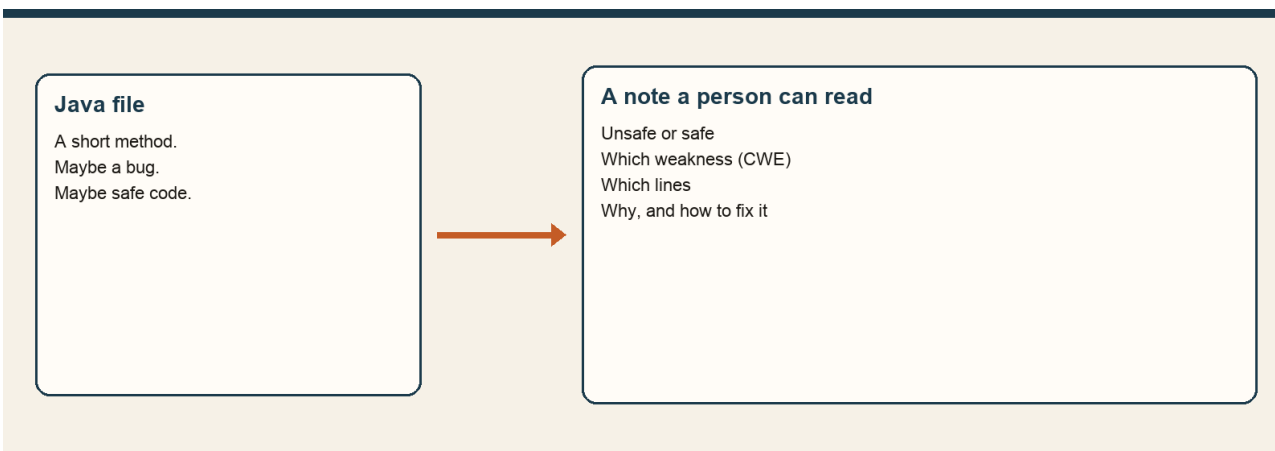
We want a tool that reads a small piece of Java and explains the risk in plain words.

The explanation should name a weakness from CWE. CWE is a public list of common software mistakes.

A useful answer says four things: unsafe or safe, which weakness, which lines, and how to fix it.

We are not trying to beat every scanner. We want an answer a person can check.

Picture



Numbers for this step only

Weakness	Plain meaning
CWE-89	SQL injection. User text is stuck into a database query.
CWE-79	Cross-site scripting. User text is shown as part of a web page.
CWE-22	A file path can be steered outside the intended folder.
CWE-502	Loading a saved object can run attacker-controlled data.
CWE-798	A password is written directly in the code.

Weakness	Plain meaning
CWE-327	The code uses weak encryption or a weak hash.

What is next

Next we will make a tiny set of Java examples, half unsafe and half safe.

What this report does not claim

This report has no test scores. We have not measured anything yet.